

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

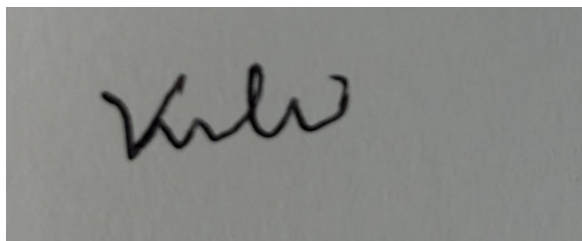
Annexure A MOCK INTERVIEW

Code of Conduct:

I _____VARSHA.S/192511358_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

A rectangular box containing a handwritten signature in black ink. The signature appears to be 'Varsha.S' written in a cursive, stylized font.

Annexure A

MOCK INTERVIEW

1. Which would you prioritize in a secure network design: **performance or security**, and how would you balance both?
2. Can you explain the difference between **stateful and stateless firewalls**, and which one is more suitable for enterprise networks?
3. If an IDS generates too many false positives, how would you optimize its performance?
4. How would you design a **real-time intrusion detection system** for high-speed networks?
5. What are the key challenges in detecting **zero-day malware**, and how would you address them?
6. How would you differentiate between **signature-based and anomaly-based IDS**, and when would you use each?
7. If a network is under a **DDoS attack**, what immediate and long-term mitigation strategies would you apply?
8. How would you secure **remote access** to an enterprise network?
9. What are the limitations of **traditional antivirus software**, and how can modern solutions overcome them?
10. How would you design a **secure email filtering system** to prevent phishing and spam attacks?
11. If an attacker bypasses firewall rules, what additional layers of security would you implement?
12. How would you evaluate the effectiveness of **network segmentation** in preventing cyberattacks?
13. What role does **encryption** play in preventing malware attacks, if any?
14. How would you secure a **cloud-based network infrastructure**?
15. What is the importance of **log analysis and monitoring** in network security?
16. How would you respond to a **security breach in a corporate network**?
17. What are the advantages and limitations of **next-generation firewalls (NGFW)**?
18. How would you integrate **IDS/IPS with SIEM systems** for better threat detection?
19. What are the best practices for **patch management and vulnerability assessment**?
20. How would you design a **future-proof network security architecture** considering emerging threats?

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge

Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problemsolving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides wellstructured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive attitude, and	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism
		professional behavior throughout			

MOCK INTERVIEW – ANSWERS

1. Which would you prioritize in a secure network design: performance or security, and how would you balance both?

I would prioritize **security**, because a fast network is not useful if it is vulnerable to attacks or data breaches. However, security should not unnecessarily reduce performance. I would balance both by using optimized firewalls, load balancing, network segmentation, efficient encryption, caching, and hardware acceleration. I would also monitor CPU usage, latency,

bandwidth, and security events continuously. The goal is to achieve **strong security with acceptable performance and low latency**.

2. Can you explain the difference between stateful and stateless firewalls, and which one is more suitable for enterprise networks?

A **stateless firewall** checks each packet independently using predefined rules such as source IP, destination IP, port, and protocol. It does not remember previous packets.

A **stateful firewall** maintains a connection table and tracks the state of active sessions. It can determine whether a packet belongs to an established or legitimate connection.

For enterprise networks, I would prefer a **stateful firewall** because it provides better context-aware security and can block unexpected packets. Stateless filtering can still be useful for simple, high-speed filtering where connection tracking is unnecessary.

3. If an IDS generates too many false positives, how would you optimize its performance?

I would first analyze the alerts to identify which rules are generating excessive false positives.

Then I would:

- Tune IDS detection rules.
- Adjust detection thresholds.
- Remove unnecessary rules.
- Whitelist trusted and known activities where appropriate.
- Improve feature selection for machine-learning models.
- Use better-quality and representative training data.
- Correlate multiple events before generating an alert.
- Continuously monitor and retrain the system.

This improves the **precision of detection** while reducing unnecessary alerts and allowing security teams to focus on genuine threats.

4. How would you design a real-time intrusion detection system for high-speed networks?

I would use a combination of **high-performance packet capture, preprocessing, feature extraction, and fast detection models**.

The system would work as follows:

Network Traffic → Packet Capture → Feature Extraction → Detection Engine → Alert → SIEM/Security Team

For high-speed networks, I would use parallel processing, optimized packet capture, efficient machine-learning models, and distributed sensors. I would also filter unnecessary traffic before deep inspection. The system should continuously monitor traffic while maintaining low latency and high throughput.

5. What are the key challenges in detecting zero-day malware, and how would you address them?

The main challenge is that zero-day malware is **previously unknown**, so traditional signature-based antivirus systems may not have a signature for it.

I would address this using:

- Behavioral analysis.
- Anomaly detection.
- Machine-learning models.
- Sandboxing.

- Endpoint monitoring.
- Threat intelligence.
- Continuous model updates.
- Application and network isolation.

Instead of looking only for known malware signatures, the system can identify **suspicious behavior**, such as unusual process activity or unexpected network communication.

6. How would you differentiate between signature-based and anomaly-based IDS, and when would you use each?

A **signature-based IDS** searches for known attack patterns or signatures. It is highly effective for known attacks but has difficulty detecting new or modified attacks.

An **anomaly-based IDS** learns what normal network behavior looks like and identifies significant deviations from that behavior. It can detect previously unknown attacks but may generate more false positives.

I would use **both together**. Signature detection provides accurate detection of known threats, while anomaly detection provides additional protection against unknown or emerging threats.

7. If a network is under a DDoS attack, what immediate and long-term mitigation strategies would you apply?

For immediate mitigation, I would:

- Identify the affected services.
- Activate rate limiting.
- Block or filter clearly malicious traffic.
- Use traffic filtering and access-control rules.
- Redirect traffic through DDoS protection services.
- Monitor bandwidth and connection rates.
- Protect critical services first.

For long-term protection, I would implement scalable infrastructure, traffic monitoring, redundant services, upstream DDoS protection, rate limiting, and a documented incident-response plan.

The objective is to **restore availability quickly and reduce the possibility of future attacks**.

8. How would you secure remote access to an enterprise network?

I would use a **VPN or Zero Trust remote-access solution** with strong authentication. Important controls include:

- Multi-factor authentication.
- Strong encryption.
- Role-based access control.
- Least-privilege access.
- Device security checks.
- Regular credential management.
- Network segmentation.
- Session monitoring and logging.

I would avoid giving remote users unrestricted access to the entire internal network. Access should be limited to the resources required for their role.

9. What are the limitations of traditional antivirus software, and how can modern solutions overcome them?

Traditional antivirus software mainly relies on known signatures. Therefore, it may have difficulty detecting:

- Zero-day malware.
- Previously unseen malware.
- Polymorphic malware.
- Rapidly modified threats.

Modern endpoint-security solutions overcome these limitations through **behavioral detection, machine learning, sandboxing, cloud-based threat intelligence, exploit detection, and real-time monitoring.**

A layered approach is more reliable than depending on signatures alone.

10. How would you design a secure email filtering system to prevent phishing and spam attacks?

I would design the system using multiple filtering layers:

Email → Sender Authentication → Reputation Check → Spam Filter → URL/Attachment Analysis → Content Analysis → Final Decision

The system would check sender reputation, authentication mechanisms, suspicious links, attachments, message content, and unusual sending patterns.

Machine-learning models can classify messages as legitimate, spam, or phishing. Suspicious messages can be quarantined for further review. Security awareness training should also be used because technical controls alone cannot prevent every phishing attack.

11. If an attacker bypasses firewall rules, what additional layers of security would you implement?

I would use **defense in depth**. Additional layers would include:

1. IDS/IPS.
2. Endpoint Detection and Response.
3. Network segmentation.
4. Multi-factor authentication.
5. Zero Trust access control.
6. SIEM monitoring.
7. Encryption.
8. Vulnerability management.
9. Application security controls.
10. Incident-response mechanisms.

This ensures that bypassing one security layer does not give the attacker unrestricted access to the network.

12. How would you evaluate the effectiveness of network segmentation in preventing cyberattacks?

I would evaluate whether segmentation limits unauthorized communication and prevents attackers from moving easily between systems.

Important measurements include:

- Number of unauthorized connections blocked.
- Reduction in lateral movement.

- Number of security incidents contained within a segment.
- Access-control violations.
- Time required to isolate compromised systems.
- Firewall and segmentation-rule effectiveness.

I would also conduct controlled security testing and review network traffic. Effective segmentation should **contain an attack and limit its impact**.

13. What role does encryption play in preventing malware attacks, if any?

Encryption primarily protects the **confidentiality and integrity of data** rather than directly preventing malware.

For example, TLS protects data while it travels across a network, while encryption of stored data protects information if storage is compromised.

However, encryption can also create challenges because attackers may hide malicious traffic inside encrypted connections. Therefore, organizations need additional security mechanisms such as endpoint detection, traffic analysis, and appropriate inspection controls.

So, encryption is an important security layer, but it should **not be considered a standalone malware-prevention mechanism**.

14. How would you secure a cloud-based network infrastructure?

I would follow a **defense-in-depth and Zero Trust approach**.

Important controls include:

- Strong identity and access management.
- Multi-factor authentication.
- Least-privilege permissions.
- Encryption of data at rest and in transit.
- Network segmentation.
- Security groups and firewalls.
- Secure configuration management.
- Vulnerability scanning.
- Continuous logging and monitoring.
- Backup and disaster recovery.

I would also regularly review cloud permissions and configurations because cloud misconfiguration is a common security risk.

15. What is the importance of log analysis and monitoring in network security?

Logs provide evidence about what is happening in the network. They help security teams detect suspicious activities, investigate incidents, and understand attack timelines.

I would collect logs from:

- Firewalls.
- Servers.
- IDS/IPS.
- Endpoints.
- Applications.
- Authentication systems.
- Cloud services.

A **SIEM system** can correlate these events and generate alerts when suspicious patterns are detected. Continuous monitoring helps organizations identify attacks earlier and respond faster.

16. How would you respond to a security breach in a corporate network?

I would follow a structured **incident-response process**:

- 1. Identification:** Detect and confirm the breach.
- 2. Containment:** Isolate affected systems to prevent further spread.
- 3. Investigation:** Determine the entry point, affected systems, and scope.
- 4. Eradication:** Remove malicious components and close the vulnerability.
- 5. Recovery:** Restore systems safely and monitor them closely.
- 6. Lessons Learned:** Analyze the incident and improve security controls.

I would also maintain proper documentation and communication throughout the incident.

17. What are the advantages and limitations of next-generation firewalls (NGFW)?

Advantages:

- Deep packet inspection.
- Application-level filtering.
- Intrusion prevention.
- User-based policies.
- Malware detection.
- Better visibility into network traffic.
- Integration with threat intelligence.

Limitations:

- Higher computational requirements.
- Greater complexity.
- Higher cost.
- Configuration requires skilled security personnel.
- Encrypted traffic can make inspection more difficult.

Overall, NGFWs provide much more advanced protection than traditional packet-filtering firewalls, especially in enterprise environments.

18. How would you integrate IDS/IPS with SIEM systems for better threat detection?

I would connect IDS/IPS sensors to the SIEM so that security events are centrally collected and correlated.

The process would be:

Network Traffic → IDS/IPS → Security Alerts → SIEM → Event Correlation → Risk Analysis → Security Alert/Response

The SIEM can correlate IDS alerts with firewall, authentication, endpoint, and server logs. This helps distinguish isolated events from coordinated attacks and reduces false positives.

Integration also provides centralized monitoring and better incident investigation.

19. What are the best practices for patch management and vulnerability assessment?

The main best practices are:

- Maintain an accurate asset inventory.
- Regularly scan systems for vulnerabilities.

- Prioritize vulnerabilities according to risk.
- Apply critical security patches quickly.
- Test patches before large-scale deployment.
- Automate patch deployment where appropriate.
- Monitor systems after patching.
- Maintain backups and rollback procedures.
- Regularly verify that patches were successfully installed.

Vulnerability assessment should be continuous rather than performed only once. This reduces the period during which attackers can exploit known vulnerabilities.

20. How would you design a future-proof network security architecture considering emerging threats?

I would design the architecture around **Zero Trust, defense in depth, continuous monitoring, automation, and adaptability**.

A suitable architecture would include:

Users/Devices → Identity Verification → Zero Trust Access → Segmented Network → NGFW/IDS/IPS → Applications/Data → SIEM/SOAR Monitoring

Key features would include:

- Zero Trust security.
- Multi-factor authentication.
- Strong encryption.
- Network segmentation.
- NGFW and IDS/IPS.
- Endpoint security.
- AI/ML-based anomaly detection.
- Continuous vulnerability management.
- Centralized SIEM monitoring.
- Automated incident response.
- Regular security testing.
- Secure cloud integration.
- Reliable backup and recovery.

A future-proof system should not depend on a single security technology. **Layered security with continuous monitoring and regular updates** allows the organization to adapt to new attack techniques while maintaining performance and availability.